

Enterprise Access Control: ¿está listo para cerrarse?

Rama 001-control-acceso-empresarial Fecha 15/09/2026

Alcance T001-T168, spec, research, data-model, contratos, ux-ui, código, base de datos y despliegue

A Veredicto

No cerrado

Suites en verde y núcleo de dominio sólido, pero con bloqueantes de seguridad, alcance y tareas.

- Defecto de seguridad crítico, confirmado en ejecución.** Cualquier usuario con alcance no vacío puede administrar todos los usuarios y reemplazar el alcance de cualquiera, incluido el suyo, por cualquier compañía activa. Anula el aislamiento por compañía (Principio I, RF-005).
- Más defectos de alcance en el histórico de personas.** Hay escrituras y lecturas que no validan la Principal ni la compañía afectada (RF-049, RF-060).
- RF-067, RF-068, RF-069 y CS-032** son obligatorios en el spec y no existen: ni contrato, ni tareas, ni código.
- Dos tareas marcadas sin su trabajo completo:** T116 (pantalla Caso A/Caso B) y T019 (índice clúster en 1 de 6 entidades).
- Contratos incumplidos:** una compañía o unidad INACTIVA no bloquea nuevas asignaciones, y `people.yaml` declara 409 para esos casos.

Unitarias 92/92 Contrato 242/242 Integración 485/485 Vitest 141/141 E2E 3/3

Migraciones 12 · cambios de modelo pendientes 0

B Estado de implementación

ÁREA	ESTADO	EVIDENCIA
US1	● DEFECTO CRÍTICO	Funciona: login, bloqueo, expiración e historial de contraseñas. Falla: <code>UsuarioService</code> no aplica alcance; <code>RequiereCambioPassword</code> solo lo aplica la UI; no hay alta del primer administrador.

ÁREA	ESTADO	EVIDENCIA
US2	● PARCIAL	Funciona: compañías, relaciones y UO aisladas por Principal, sin ciclos. Falla: una compañía o UO INACTIVA no bloquea asignaciones; <code>TipoCompania</code> se puede reclasificar sin validar dependientes.
US3	● COMPLETA	Semilla de Perú en migración versionada; RF-032 aplicado a los catálogos maestros.
US4	● COMPLETA	Unicidad de documento, búsqueda dentro del alcance, p95 45 ms con 100 000 personas.
US5	● PARCIAL	Backend completo: triggers, contención, cascada, fecha futura, renovación y revalidación. Defectos: alcance (D-2), INACTIVA (D-4), UI incompleta (T116: no se puede crear pertenencia, contexto ni perfil) y fechas mostradas con un día de desfase.
US6	● COMPLETA	Árbol de áreas, aislamiento entre Principales, rechazo de ciclos y de movimientos entre árboles.
US7	● COMPLETA	Tipos de persona por área, con 404 fuera de alcance y rechazo de maestro inactivo.
US8	● COMPLETA	Motor de 14 pasos puro, precedencia, gate de credencial, p95 13 ms, E2E de quickstart §5 y §6.
US9	● COMPLETA	Decisión A verificada; asignar, devolver y eliminar; la baja pide confirmación.
US10	● PARCIAL	Estampado automático probado. Las consultas transversales de auditoría, históricos e indicadores (RF-067 a RF-069) no existen.

c Cobertura de requisitos

Las filas se agrupan solo cuando comparten implementación y pruebas. Las referencias D-n y E remiten a las secciones D y E.

REQUISITO	IMPLEMENTADO	PRUEBA	OBSERVACIÓN
REQUISITOS FUNCIONALES			

REQUISITO	IMPLEMENTADO	PRUEBA	OBSERVACIÓN
RF-001, 002	● SÍ	Integración, contrato	—
RF-003	● SÍ	Unitaria, integración, contrato	Umbrales provisionales (decisión #1)
RF-004	● SÍ	Integración, contrato	—
RF-005	● PARCIAL	Integración (personas, compañías, áreas, UO, permisos, evaluación)	Usuarios sin alcance (D-1); histórico de persona (D-2)
RF-006 a 009	● SÍ	Integración, contrato, Tree	—
RF-010	● SÍ	Integración, frontend	—
RF-011	● SOLO API	Integración	Sin pantalla; no rechaza perfiles duplicados solapados (D-9)
RF-012	● SÍ	Integración, contrato, frontend	—
RF-013	● PARCIAL	Integración, contrato	La UI muestra el UUID cuando no resuelve un nombre
RF-014, 015	● SÍ	Integración (triggers)	Ver D-6
RF-016	● PARCIAL	Unitaria, integración	Normaliza al día UTC, no al de Lima; desfase visual en la UI (E)
RF-017	● SÍ	Integración	—
RF-018	● SÍ	Integración	Lista credenciales de Principales fuera de alcance (D-2)

REQUISITO	IMPLEMENTADO	PRUEBA	OBSERVACIÓN
RF-019 a 022	● SÍ	Unitaria, integración, contrato, E2E	—
RF-023 a 025	● SÍ	Unitaria, integración, E2E	—
RF-026, 027	● SÍ	Integración, contrato	—
RF-028, 029, 033	● SÍ	Indirecta	—
RF-030	● SÍ	Frontend	Existen pantallas para las entidades que enumera el RF
RF-031	● SÍ	Integración	—
RF-032	● PARCIAL	Integración (persona, tipos, credencial)	Compañía o UO INACTIVA no bloquea (D-4)
RF-034	● SÍ	Integración (endurecimiento)	Exigir autorización no garantiza el alcance (D-1)
RF-035	● SÍ	Integración, rendimiento	—
RF-036	● SÍ	Frontend (accesibilidad)	—
RF-037	● SÍ	Integración, contrato	—
RF-038	● SÍ	Unitaria, integración, E2E	—
RF-039	● SÍ	Unitaria, integración (triggers)	La cascada puede dejar intervalos invertidos (E)
RF-040	● PARCIAL	Contrato (242)	Faltan los contratos de RF-067 a RF-069 (D-3)

REQUISITO	IMPLEMENTADO	PRUEBA	OBSERVACIÓN
RF-041	● SÍ	Integración, contrato	—
RF-042	● SÍ	Integración, contrato, frontend	Reclasificación sin validar dependientes (E)
RF-043 a 048	● SÍ	Unitaria, integración, contrato, E2E	—
RF-049	● PARCIAL	Integración	La asignación de UO no valida el alcance sobre la Principal (D-2)
RF-050 a 052	● SÍ	Integración, contrato, E2E	—
RF-053, 054	● SOLO BACKEND	Unitaria, integración, E2E vía API	No hay pantalla Caso A/Caso B (D-5)
RF-055 a 059	● SÍ	Unitaria, integración, contrato, E2E	RF-057 = Decisión A, verificada
RF-060	● PARCIAL	Integración	Los listados de contextos no filtran por Principal (D-2)
RF-061 a 065	● SÍ	Unitaria, integración	Dependientes futuros quedan con fin anterior al inicio (E)
RF-066	● SÍ	Unitaria, integración	—
RF-067 a 069	● NO	—	Sin contrato, tarea ni código (D-3)
RF-070 a 073	● SÍ	Unitaria, integración, contrato, frontend	—
CRITERIOS DE ÉXITO			
CS-001	● SÍ	Sin medición	No hay prueba de tiempo de login

REQUISITO	IMPLEMENTADO	PRUEBA	OBSERVACIÓN
CS-002, 003	● SÍ	Rendimiento (p95 45 ms / 13 ms)	—
CS-004	● PARCIAL	Integración	Política en el 100 % de endpoints, pero alcance efectivo roto (D-1, D-2)
CS-005 a 008	● SÍ	Integración, contrato, unitaria	—
CS-009	● PARCIAL	E2E vía API	No se puede completar desde la UI (D-5)
CS-010	● SÍ	Integración indirecta	Sin prueba explícita de dos raíces en la misma Principal
CS-011 a 018	● SÍ	Integración, E2E §6	—
CS-019, 020	● BACKEND	Integración	La UI no permite abrir contextos
CS-021	● NO	—	Pantalla Caso B inexistente (D-5)
CS-022 a 031	● SÍ	Integración (gate de credencial, revalidación, revocación)	—
CS-032	● NO	—	D-3
CS-033 a 035	● SÍ	Unitaria, integración	—

D Contradicciones reales

D-1

Administración de usuarios sin alcance

• CRÍTICA

DOCUMENTO	RF-005, Principio I, Historia 1 criterio 4, CS-004.
CÓDIGO	<code>UsuarioService.cs:24</code> lista sin filtro; <code>UsuarioService.cs:179</code> y <code>:217</code> solo validan que la compañía exista y esté activa; <code>CompaniaScopeAuthorizationHandler.cs:39</code> solo exige alcance no vacío.
IMPACTO	- Un usuario "ajeno" obtuvo en <code>GET /api/usuarios</code> los 6 usuarios del sistema y sus alcances, con ID de compañías fuera del suyo (lectura real contra el entorno E2E). - Con esos ID puede hacer <code>PUT</code> sobre su propio alcance, volver a iniciar sesión y ver cualquier compañía. La escritura no se ejecutó; se deduce directamente del código. - También puede crear usuarios e inactivar o desbloquear a cualquiera.
TIPO	Defecto real. Corregirlo exige decidir un modelo de administración que el spec no define (no hay roles).

D-2

Histórico de persona fuera de alcance

• ALTA

DOCUMENTO	RF-049, RF-060, RF-005.
CÓDIGO	<code>AsignacionUnidadOrganizativaService.cs:30</code> no valida que la Principal del contexto esté en alcance. <code>ContextoOperativoService.cs:33</code> , <code>CredencialService.cs:58</code> y el listado de UO devuelven datos de Principales fuera de alcance. <code>HistorialPersonaService.cs:108</code> y <code>:158</code> finalizan o renuevan una pertenencia con solo tener alcance sobre alguna compañía del histórico (<code>PersonaService.cs:223</code>).
IMPACTO	Un administrador de la contratista reasigna UO de una Principal ajena o dispara la cascada sobre la pertenencia de otra compañía. Ninguna prueba cubre estos casos.
TIPO	Defecto real, confirmado por inspección del código.

D-3

RF-067, RF-068, RF-069 y CS-032 sin implementar

• ALTA

DOCUMENTO	<code>spec.md:1045-1056</code> , RF-040.
CÓDIGO	No existe. <code>tasks.md:1117</code> y <code>plan.md</code> los excluyen de forma explícita por falta de contrato.
IMPACTO	Historia 10 y las pantallas de Dashboard, Históricos y Auditoría (<code>ux-ui.md</code> §8, §20, §21) están incompletas; el menú muestra "Dashboard" como pantalla pendiente.
TIPO	Implementación incompleta respecto del spec; requiere decisión humana (diseñar los contratos o reprogramar formalmente).

D-4

Compañía o UO INACTIVA no bloquean asignaciones

• MEDIA

DOCUMENTO	Historia 2 criterio 6; <code>people.yaml:171</code> y <code>:363</code> (409); <code>data-model.md:211</code> , <code>:354</code> y <code>:470</code> .
CÓDIGO	<code>CrearAsignacionAsync</code> y <code>AsignarAsync</code> (UO) no comprueban <code>Estado</code> ; tampoco lo hace el permiso de alcance COMPañÍA.
IMPACTO	Se aceptan con 201 asignaciones que el contrato declara 409. Sin pruebas.

D-5

T116 y pantalla Caso A / Caso B

• MEDIA-ALTA

DOCUMENTO	<code>tasks.md:641</code> , Historia 5 "Comportamiento de la pantalla", CS-021, <code>ux-ui.md</code> §13 y §15.
CÓDIGO	<code>AsignacionUnidadOrganizativa.tsx</code> exige un contexto ya existente y usa un selector plano, no un árbol. <code>useCrearPertenencia</code> y <code>useAbrirContexto</code> están definidos, pero ninguna pantalla los usa. No hay UI de perfiles.
IMPACTO	La historia 5 no es operable desde la interfaz, solo por API.
TIPO	Tarea marcada sin el trabajo.

D-6

Reemplazo de una pertenencia ya vencida

• BAJA-MEDIA

DOCUMENTO	<code>data-model.md:372-375</code> : "la anterior no se modifica... con Estado sin cambios".
CÓDIGO	<code>HistorialPersonaService.cs:79-85</code> marca siempre la previa ACTIVA como FINALIZADA con motivo REEMPLAZO_ASIGNACION.
IMPACTO	Motivo administrativo falso en el histórico; no afecta al acceso.

D-7

"Finalizar" pertenencia sin confirmación

• MEDIA

DOCUMENTO	<code>ux-ui.md §2 y §15</code> : impacto y confirmación antes de actuar.
CÓDIGO	<code>PersonaHistorialPage.tsx:124-136</code> ejecuta la cascada con un clic y usa siempre la fecha actual. La prueba "finaliza la pertenencia al confirmarlo" no verifica ninguna confirmación.

D-8

T019: índice clúster por `CreatedAt`

• MEDIA

DOCUMENTO	<code>research.md §20</code> y T019: 6 entidades de histórico.
CÓDIGO	<code>ConfiguracionExtensions.cs:28</code> solo se aplica en <code>UsuarioConfiguration.cs:54</code> (<code>HistorialContraseña</code>). Confirmado en el snapshot del modelo.
IMPACTO	Fragmentación con clave GUID en los 5 históricos de

Diferencias solo documentales, sin impacto funcional

- **Rutas de `tasks.md`:** las de T006, T020 y T103-T106 no coinciden con los archivos reales; el trabajo existe, consolidado en otros archivos.
- **`research.md`:** §7 paso 5 usa `SIN_CONTEXT0...`, mientras el contrato y el código usan `RELACION_CONTRATISTA_PRINCIPAL_VENCIDA`. §8 menciona semillas de `TipoPersona` y `TipoCredencial` que el spec declara no obligatorias.
- **Contratos:** `access-evaluation.yaml` incluye 3 motivos que la API nunca devuelve (esos casos son 404); `credentials.yaml` no declara 404/409 en DELETE y devolver.
- **`data-model.md`:** cierra la pertenencia previa "a las 23:59 del día anterior"; el código la cierra a las 00:00 del nuevo inicio, que es equivalente.

"ahora".

E Riesgos técnicos

● CRÍTICO

- D-1: escalada de alcance.

● ALTO

- **Falta el filtro global de alcance** (`HasQueryFilter`) que prescriben `research.md` §3 y §18. Cada servicio aplica el alcance a mano, y ese es el origen de D-1 y D-2: un olvido no deja rastro.

● MEDIO

- **Contraseña pendiente de cambio:** `RequiereCambioPassword` solo lo aplica la UI (`RutaProtegida.tsx:29`); el token es plenamente operativo por API.
- **Tokens no revocables:** el JWT sigue valiendo tras inactivar al usuario o cambiar su alcance, hasta 60 minutos.
- **Días normalizados en UTC** (`Vigencia.cs:19`). En Lima, una vigencia empieza a las 19:00 del día anterior y termina a las 18:59 del último día. La UI envía `fecha T00:00:00Z` y lo muestra con `toLocaleDateString()`, así que el inicio aparece un día antes. La visualización es un defecto; la zona de normalización es una ambigüedad a decidir.
- **Reclasificación de compañía:** `TipoCompania` es editable con dependientes (`CompaniaService.cs:95`); una Principal con áreas y UO puede pasar a CONTRATISTA.
- **Compañía INACTIVA y evaluación:** el motor no mira `Compania.Estado` (`EvaluadorDeAcceso.cs:151`). Ver decisión #6 en F.
- **Índice clúster (D-8):** riesgo de fragmentación a la escala de CS-002.

● BAJO

- **Intervalos invertidos:** la cascada o la devolución de una asociación que aún no empezó deja `FechaHoraFin < FechaHoraInicio` (`RevocacionService.cs:58`). Nunca resulta vigente y no hay CHECK.
- **Sujeto de permiso sin validar:** no se comprueba Principal, estado ni alcance (`PermisoAccesoService.cs:258`). Inocuo en la evaluación, pero el 400 permite comprobar si un ID existe.
- **Personas sin histórico:** cualquier administrador puede escribir sobre ellas si conoce su ID.
- **Sesión expirada:** un 401 borra la sesión sin notificar al guard (`apiClient.ts:73`); la redirección espera a la siguiente navegación.
- **UUID visible:** la UI lo muestra como respaldo (RF-013).
- **E2E:** reutiliza los contenedores de desarrollo y deja la API apuntando a la base `_E2E` (documentado).

F Decisiones de negocio abiertas

DECISIÓN	ESTADO	OBSERVACIÓN
#1 Política de contraseñas	● ABIERTA	Umbral configurable marcado como provisionales; sin flujo de recuperación. No se cerró de forma implícita.

DECISIÓN	ESTADO	OBSERVACIÓN
#3 Retención legal	● ABIERTA	Sin purga ni archivado.
#6 Cascada por relación o compañía inactiva	● ABIERTA, CON MATIZ	No hay cascada en ninguno de los dos casos, correcto. Pero <code>spec.md:1283</code> afirma que la compañía INACTIVA queda "protegida por la re-validación dinámica", y el motor no consulta <code>Estado</code> . Esa protección no existe; conviene tenerlo en cuenta al decidir.
#7 Prioridad de Historia 9	● ABIERTA	Sigue en P2 en el spec; se implementó por secuenciación técnica, sin prejuzgar la prioridad.

G Huecos de producto y operación

● CONFIRMADO

Primer administrador

No hay semilla ni endpoint anónimo. En un despliegue limpio verificado, la tabla `Usuario` quedó con 0 filas. Además, por D-1 no existe el concepto de administrador: cualquier usuario con alcance puede darse cualquier alcance. Requiere decisión.

● CONFIRMADO

Alcance al crear compañías

`CompaniaService.CrearAsync` no añade la compañía al alcance de quien la crea. Hoy solo se resuelve con el `PUT` de alcance sin restricciones de D-1. Requiere decisión.

● DOCUMENTAL

CREDENCIAL_REVOCADA en ux-ui.md frente al contrato

- El spec ya lo resolvió de forma explícita: un único motivo `SIN_CREDENCIAL_VIGENTE`, con el detalle solo como texto.
- Contrato, backend y frontend son coherentes entre sí.
- `ux-ui.md` (líneas 393 y 491, y §17 con "Motivo CESE_PERTENENCIA" en una credencial, que `research.md` §23 descarta) quedó desactualizado.
- No hace falta decisión de negocio; solo actualizar `ux-ui.md`.

H Cobertura de pruebas

Cubierto con solidez

- **Motor de evaluación:** pasos, precedencia y gate, en unitarias puras e integración.
- **Temporalidad:** triggers contra SQL Server real, contención, cascada (incluida la fecha futura), renovación y revalidación dinámica.
- **Decisión A:** 4 casos de solapamiento y verificación de `RowVersion`.
- **Aislamiento** de compañías, personas, áreas, UO y permisos.
- **Auditoría y rendimiento** (CS-002, CS-003).
- **E2E** de quickstart §5 y §6, con un fallo provocado que confirmó que las aserciones evalúan la respuesta real.

Requisitos importantes sin prueba directa

- Alcance en administración de usuarios (D-1).
- Asignación de UO, listados por Principal y finalizar/renovar fuera de alcance (D-2).
- Compañía o UO INACTIVA en pertenencia, UO y permiso (D-4).
- Cascada sobre dependientes que aún no empezaron.
- Normalización de días cerca de la medianoche de Lima y visualización de fechas.
- Confirmación antes de finalizar una pertenencia.
- Reclasificación de `TipoCompania` con dependientes.
- CS-001, CS-021, CS-032 y RF-067 a RF-069.

Validaciones ejecutadas en la auditoría: compilación del backend con 0 advertencias, unitarias, contrato e integración completas, comprobación de cambios de modelo, lista de migraciones, Vitest, tsc, eslint, prettier, build del frontend, E2E y una lectura de la API E2E que confirmó la fuga del listado de usuarios.

I Preparación para el despliegue

PREGUNTA	RESPUESTA	MOTIVO
¿Infraestructura desplegable desde cero?	● SÍ	Verificado en un proyecto aislado: sin secretos compose no arranca, se aplicaron las 12 migraciones y <code>/health/ready</code> pasó de 503 a 200.
¿Operable desde cero siguiendo README.md?	● NO	Hay que insertar el primer usuario a mano en la base (el README lo documenta como hueco abierto) y el proxy inverso solo está descrito como requisitos.

PREGUNTA	RESPUESTA	MOTIVO
¿Listo para producción?	• NO	Por D-1 y D-2, cualquier usuario autenticado equivale a un superadministrador.

Cambios recomendados

• **BLOQUEANTE** Debe corregirse antes de considerar el proyecto cerrado

1. Decidir el modelo de administración de usuarios y corregir D-1, con pruebas.
2. Aplicar el alcance en asignación de UO, listados de contextos, UO y credenciales, y finalizar/renovar (D-2), con pruebas.
3. Decidir RF-067 a RF-069 y CS-032: diseñar contratos y tareas, o reprogramarlos formalmente mediante cambio de spec (D-3).
4. Resolver T116 y T019: completarlas o reabrir las de forma explícita (D-5, D-8).
5. Decidir y documentar el mecanismo de alta del primer administrador.

• **IMPORTANTE** Recomendable, no bloquea

6. Validar compañía y UO INACTIVA según los contratos (D-4).
7. Decidir la zona horaria de normalización de días y corregir la visualización de fechas en la UI.
8. Añadir confirmación, impacto y fecha efectiva a "Finalizar pertenencia" (D-7).
9. Decidir si el servidor debe aplicar `RequiereCambioPassword`.
10. Validar la reclasificación de `TipoCompania` con dependientes.
11. Decidir el alcance al crear compañías.
12. Aclarar en la decisión #6 el caso de compañía INACTIVA frente a la evaluación.
13. Añadir el filtro global de alcance como segunda línea de defensa (research.md §3).
14. Alinear la documentación: D-6, D-10, research.md §7, 404/409 en contratos, `CREDENCIAL_REVOCADA` en ux-ui.md y rutas de tasks.md.

• **OPCIONAL** Mejora futura

15. Evitar intervalos invertidos, con CHECK o ajuste del cierre.
16. Rechazar perfiles duplicados solapados (D-9).
17. Validar el sujeto de los permisos.
18. Notificar al guard de sesión ante un 401.
19. Medir CS-001.
20. Separar el entorno E2E del compose de desarrollo.

K Veredicto final

¿El proyecto está realmente terminado? **No.**

¿Hay algún defecto que corregir antes de producción?	Sí: D-1 (crítico) y D-2, además del alta del primer administrador.
¿Hay contradicciones entre spec y código?	Sí: RF-005, RF-049 y RF-060; Historia 2 criterio 6 y RF-032 frente a los contratos; RF-067 a RF-069 y CS-032; CS-021; data-model.md en D-6, D-9 y D-10.
¿Hay tareas de tasks.md marcadas incorrectamente?	Sí: T116 (no existe la pantalla Caso A/Caso B) y T019 (índice clúster en 1 de 6 entidades). Las rutas distintas de T006, T020 y T103–T106 son solo documentales.
¿Las decisiones #1, #3, #6 y #7 siguen abiertas correctamente?	Sí, ninguna se resolvió de forma implícita. En #6, el spec supone una protección dinámica ante compañía INACTIVA que el código no aplica.
¿T001–T168 es una implementación completa?	No. Dos tareas están marcadas sin su trabajo, el plan excluyó RF-067 a RF-069 y quedan defectos de alcance que ninguna tarea obligaba a probar.
¿Cuál es el siguiente paso recomendado?	Una sesión de decisiones con negocio sobre el modelo de administración de usuarios, el primer administrador, RF-067 a RF-069, la zona horaria de normalización y la decisión #6. Después, un ciclo de corrección que añada las tareas faltantes sin regenerar tasks.md.

Auditoría en modo solo lectura: no se modificó código, especificación ni tasks.md. Las pruebas E2E añadieron datos a la base temporal `EnterpriseAccessControl_E2E` y se regeneraron artefactos de compilación y reportes de prueba. Las referencias `archivo:línea` son relativas a la raíz del repositorio.